

NATIONAL CYBERSECURITY LAW

Design Project for VIT — Academic Assignment

Subject

Cybersecurity Law &
Policy

Project Type

Group / Individual Project

Total Marks 100

Marks

Deliverables

Report + Presentation + Flowcharts +
Infographics

Important Notice to Students

This is a comprehensive project assignment. Read all sections carefully before starting. Your team must draft a complete Cybersecurity Law for the fictional country of VIT's. Each part of this project corresponds to a section of the law you will create. Be creative, thorough, and technically accurate.

Name	Siddhi Naik / Gauri Desai
Roll Number	24105A0047 / 24105A0021
Email id	siddhi.naik@vit.edu.in / gauri.desai@vit.edu.in
Contact Number	8850053255 / 8591374720

PART 1: Introduction

Purpose of the Law

This legislation is designed to establish a definitive, enforceable legal governance framework over the digital sovereign territory.

Its primary purpose is to:

- Define, classify and mandate protections.

- **Codify clear criminal penalties for illicit cyber activities, creation statutory paths for modern law enforcement investigations.**
- **Enforce rigorous data protection obligations on private and public entities to safeguard the personal, financial and medical information of individual.**
- **Establish authorized, unified federal cyber commands capable of domestic threat intelligence surveillance and rapid incident response.**

Importance of Cybersecurity

As a rapidly growing digital power with 50 million active users, our nations economic engine and societal stability now run entirely on digital rails. The rapid deployment of online banking, e-commerce, AI-based public services, cloud-reliant enterprises and interconnected smart city infrastructures means that a vulnerability in code directly translates to a threat to physical life and national wealth.

With 50 million citizens exposed online, cybersecurity is no longer an isolated technical concern it is a core pillar of national security. Left unregulated, a single coordinated exploitation could paralyze the economy, dismantle public trust and compromise national sovereignty. This law provides the immediate legal teeth required to secure this vast, hyper-connected landscape.

Challenges Faced

The urgency of this legislation is driven by a series of severe, compounding cyber incidents that have exposed vulnerabilities across digital platforms.

- **Systemic Financial Fraud and Identity Theft**
- **Data breaches**
- **Social Destabilisation**
- **Ransomware Attacks**

Goals and Expected Outcomes

The enactment of this legislation transforms the nation's defensive posture from a fragmented, reactive approach to a resilient, unified, and proactive stance.

Expected Outcomes:

- **Uniform, legally mandated security baselines and audited penetration testing.**
- **Streamlined judicial warrants and standardized digital forensics workflows.**
- **Secure digital assets protected by strict entity liability and continuous public hygiene programs.**

PART 2: Definitions Section

Define at least 20 important cyber law terms. Your definitions must be precise, legally clear, and relevant to VIT's context. Below are the required terms — you may add more.

Required Terms to Define

#	Term	Definition (To Be Completed by Student)
1	Cybercrime	Any illegal activity that involves networks, digital devices, computers or internet. Eg: hacking
2	Hacker	A person who access or modify devices, computer systems. They can act legally or illegally.
3	Ethical Hacker	Ethical hacking is called white hat hacking, it is practice of intentionally penetrating a computer system or network with permission to find vulnerabilities.
4	Malware	It is program that intentionally harms and gains unauthorized access to a computer or network.
5	Ransomware	It is a type of software that encrypts files and demands payment to restore access. It often steals data and threatens to leak it.
6	Phishing	It is a social engineering attack where an attacker impersonates a entity like bank, employer to trick people into revealing OTPs, passwords or other sensitive information.
7	Data Breach	In data breach information is accessed, stolen or exposed without authorization. It can result from hacking, lost devices etc.
8	Personal Data	Information that relates to a person like phone number, IP address, name, Adhaar card etc.
9	Sensitive Data	A data that requires stronger protection because it can be misused or can cause harm. Eg: passwords, biometric data.
10	Digital Signature	A cryptographic mechanism that proves a digital document was signed by a specific private key and has not been altered since signing.
11	Electronic Evidence	Any information that is stored or transmitted in digital form that may be used in an investigation.

12	Identity Theft	Fraudulent use of another person's information such as passwords, bank details, account credentials to commit fraud.
13	Artificial Intelligence	Computer system designed to perform tasks that normally require human intelligence such as recognizing patterns or generating content
14	Cloud Computing	Delivery of computing resources like databases, servers and software over the internet on demand rather than owning and operating locally.
15	Critical Infrastructure	Systems and assets whose disruption would seriously affect public safety, national security or economy. Eg: water supply, banking systems.
16	Cyberbullying	Using digital platforms such as social media to threaten, humiliate, harass or target a person repeatedly.
17	Deepfake	It is a synthetic media created often with AI to depict a person saying or doing something they never actually said or did.
18	Encryption	The process of converting plain text into ciphertext using a cryptographic key.
19	Firewall	It is a software that monitors and filters network traffic according to rules allowing authorized communication and blocking unauthorized traffic.
20	Zero-Day Exploit	It is an attack that exploits a software vulnerability before vendor has released a fix. The vulnerability is known to attackers for zero days from the defender's perspective.

PART 3: Digital Rights

Create a comprehensive Bill of Digital Rights for every citizen of VIT's. For each right, provide a clear explanation of what it means and how it will be enforced.

Required Rights

Right to Privacy

Citizens must be protected from unauthorized collection, use, or sharing of their personal data. Backed by the landmark Supreme Court judgment Justice K.S. Puttaswamy v. Union of India (2017), which recognized privacy as a fundamental right under privacy as a fundamental right under Article 21 of the Constitution. Under the DPDP Act, this is codified through Mandatory Consent. No company can process your

personal data unless it is for a lawful purpose and you have given free, specific, informed, and unconditional consent via a clear affirmative action.

Data Fiduciaries are responsible.

Enforcement:

Before asking for data, the company must present you with a clear consent notice detailing exactly what is being collected and why. If they track you without this, you can file a complaint with the Data Protection Board of India (DPBI), which can levy massive financial penalties up to Rs 250 crores for non-compliance.

Right to Secure Data

All organizations must store and protect citizens' data using industry-standard security measures.

Section 8(5) of the DPDP Act, 2023 explicitly mandates that Data Fiduciaries must implement reasonable security safeguards to prevent personal data breaches.

The Data Fiduciaries and their appointed Data Protection Officers are responsible.

Enforcement:

- **Technical Compliance:** Companies must deploy encryption, firewalls, and access controls.
- **The Breach Penalty:** If a hack occurs because a company was careless with security, they are legally obligated to report the breach to both you and the DPBI. Failing to maintain data security safeguards attracts a direct statutory penalty of up to Rs 250 crores.

Right to Data Deletion

Citizens may request the complete deletion of their personal data from any organization's systems.

Section 12 of the DPDP Act, 2023 grants the individual the right to correction and erasure. You have the right to demand the deletion of personal data that is no longer necessary for the purpose it was collected.

Data Fiduciaries are responsible.

Enforcement:

You can log into an app or platform and hit Delete Account or formally request data removal. Once the original business purpose is fulfilled, or if you choose to withdraw your consent, the company is legally required to erase your data from

their servers and ensure their third-party storage partners do the same. If they refuse, it is a direct violation remediable by the DPBI.

Right to Information

Citizens have the right to know what data is collected about them and how it is used.

Section 11 of the DPDP Act, 2023 gives citizens the right to obtain information about their personal data.

Data Fiduciaries and their customer grievance cells.

Enforcement:

You have the right to request a summary of all personal data a company holds on you, what processing activities they have performed with it, and the identities of any third parties they have shared your data with. Companies must provide this information in a clear, easily understandable format.

Right to Report Cybercrime

Citizens can report cybercrimes without fear of retaliation, and authorities must act within defined timeframes.

Governed by the IT Act, 2000 and supported by Ministry of Home Affairs directives. Cybercrimes are classified as cognizable offences, meaning police are legally bound to register the crime.

Local police cyber cells, the National Cybercrime reporting portal, and designated grievance officers of tech intermediaries.

Enforcement:

- **Online Reporting:** Citizens can log onto the central portal cybercrime.gov.in to report financial fraud, cyberstalking, or identity theft anonymously or openly.
- **Intermediary Takedowns:** If the crime involves non-consensual intimate imagery, under the IT Rules 2021, platforms are legally forced to take down the flagged content within 24 hours of receiving a user report.

Right to Fair Investigation

Any person accused of a cybercrime is entitled to a fair, transparent, and timely investigation.

Section 78 of the IT Act, 2000 dictates that only a police officer of the rank of Inspector or Above has the authority to investigate cyber offences. This is paired with digital forensics rules under the BNSS, 2023, which mandate strict guidelines for handling digital evidence to avoid tampering.

The police Investigative Officers, Cyber Forensics Laboratories, and CERT-In (Indian Computer emergency Response Team) for technical back-end assistance are responsible.

Enforcement:

- **Hash Value Logging:** To ensure an investigation is fair and evidence isn't planted, law enforcement must immediately record the unique cryptographic hash value of any seized electronic device at the crime scene.
- **Judicial Oversight:** The final investigative report must be verified by specialized cyber-law magistrates. If the police fail to investigate diligently or break data forensic protocols, citizens can appeal to the judicial court or an Adjudicating Officer for an independent review.

Right to Identity Protection and Authenticity

Every citizen has the right to protect their digital likeness and a guarantee that synthetic media like deepfake will be identifiable. The rise of generative AI makes it terrifyingly easy to clone a person's voice, face, and identity without their consent. This right protects citizens from malicious deepfakes, non-consensual synthetic imagery, and algorithmic identity theft.

Enforcement:

- **Digital Watermarking Mandates:** Forcing AI developers to embed invisible, unalterable cryptographic watermarks into all AI-generated content at the source.
- **Right of Publicity Laws:** Extending existing intellectual property and likeness laws to heavily penalize the unauthorized commercial or malicious use of a private citizen's digital twin.

Right to Digital Disconnection

Citizens have the right to disconnect from their digital workspaces outside of official working hours without facing professional retaliation.

The always on nature of smartphones and remote work has blurred the boundaries of personal time, leading to widespread mental burnout. Citizens must

have a legally protected right to step away from the digital grid to preserve their well-being.

Enforcement:

- **Labor Code Integration:** Legal statutes preventing employers from penalizing employees who do not reply to emails, texts, or digital pings during weekends, holidays, or post-work hours.
- **Automated Off-Hours:** Encouraging or mandating company-wide server settings that queue non-urgent digital communications until the next business morning.

Right to Algorithmic Transparency and Fairness

Citizens have the right to know when an AI or algorithm is making a decision that affects their life, and the right to human review.

Algorithms increasingly determine who gets a loan, who gets a job interview, or how a judicial sentence is passed. If these systems are trained on biased data, they automate discrimination. Citizens shouldn't be subjected to black box decisions that alter their lives.

Enforcement:

- **Algorithmic Audits:** Mandating independent, third-party bias and accuracy testing for high stakes AI systems before they deploy.
- **The Right to Explanation:** If an AI denies a loan or an application, the company must legally provide a clear, human readable breakdown of why that decision was reached.

Right to Digital Privacy and Decryption

Every citizen has the right to private, unmonitored digital communications and access to end-to-end encryption without government backdoors.

Mass surveillance destroys free speech. Citizens must be free from unwarranted tracking by both corporate data brokers and state entities. Encryption is the digital equivalent of a sealed envelope forcing companies to build backdoors for law enforcement inherently breaks security for everyone.

Enforcement:

- **Warrant Requirements:** Strict judicial oversight requiring law enforcement to prove probable cause before intercepting digital communications or accessing smart device data.
- **Banning Data Brokers:** Restricting or criminalizing the bulk collection, packaging, and unauthorized sale of location and behavioural data.

Right to Digital Privacy and Decryption

Every citizen has the right to private, unmonitored digital communications and access to end-to-end encryption without government backdoors.

Mass surveillance destroys free speech. Citizens must be free from unwarranted tracking by both corporate data brokers and state entities. Encryption is the digital equivalent of a sealed envelope forcing companies to build backdoors for law enforcement inherently breaks security for everyone.

Enforcement:

- **Warrant Requirements:** Strict judicial oversight requiring law enforcement to prove probable cause before intercepting digital communications or accessing smart device data.
- **Banning Data Brokers:** Restricting or criminalizing the bulk collection, packaging, and unauthorized sale of location and behavioural data.

Right to Universal Digital Access and Literacy

Every citizen has the right to a secure, affordable, and high-speed internet connection, alongside the education required to navigate it safely.

The digital divide is a major driver of economic inequality. Without access to the internet, citizens are cut off from modern education, job markets, healthcare, and government services. Access must be treated as a fundamental public utility, much like water or electricity.

Enforcement:

- **Universal Service Funds:** Governments mandate telecommunication companies to invest in rural and low-income infrastructure.
- **Net Neutrality Laws:** Strict prohibition of internet service providers throttling, blocking, or creating paid fast lanes for specific content.
- **Public Curriculums:** Mandatory, state funded digital literacy and cybersecurity safety training in public education.

BILL OF DIGITAL RIGHTS FOR EVERY CITIZEN

"DIGITAL RIGHTS = DIGITAL FREEDOM + DIGITAL SECURITY"



PART 4: Cyber Offenses and Crimes

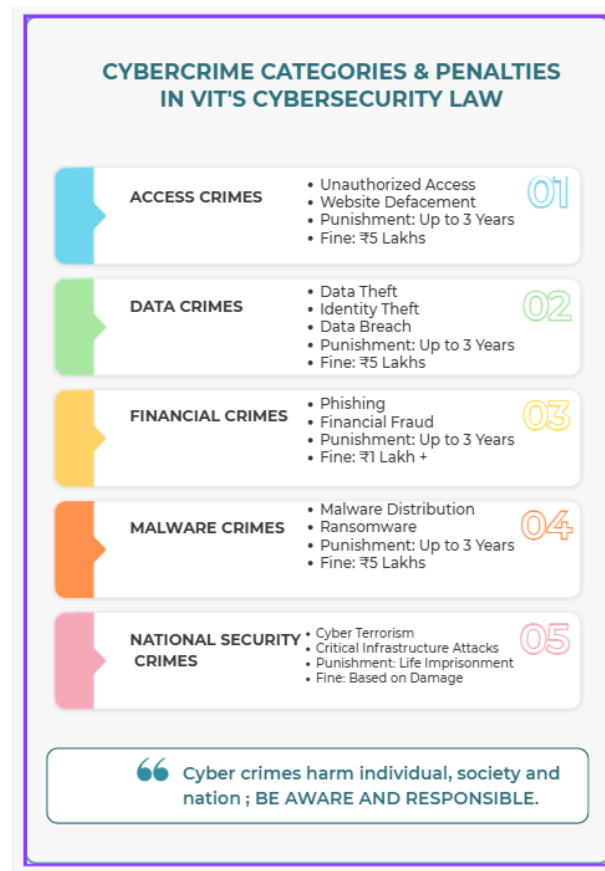
Define categories of cybercrime. For each offense, specify a description, real-world example within VIT's context, criminal punishment, and financial fine. Complete the table below.

Crime	Description + Example	Punishment	Fine
Unauthorized Access	Gaining entry into a computer system, network or data without the explicit permission of the owner or person in charge. Eg: An individual used a colleague's login	Up to 3 years of imprisonment.	Up to Rs. 5 lakhs.

	credentials without their knowledge to browse restricted databases.		
Data Theft	Actively copying, downloading or stealing personal data or confidential information from a system without authorization. Eg: An employee copied a client contact list onto a personal USB drive right before resigning.	Up to 3 years of imprisonment.	Up to Rs. 5 lakhs.
Identity Theft	Fraudulently making use of another person's unique electronic identification features, such as digital signatures, passwords or Aadhaar numbers. Eg: An individual created a fake social media profile using someone else's real photo, name.	Up to 3 years of imprisonment.	Up to Rs. 1 lakh.
Phishing	A technique where attackers send fraudulent messages designed to look like a trustworthy entity to trick users into revealing sensitive data. Eg: One student received an email that looked exactly like a message from a bank, stating that his account is suspended unless you click a link and re-enter net banking password.	Up to 3 years of imprisonment.	Up to Rs. 1 lakh along with penal fines under cheating laws.
Ransomware	A malicious software that encrypts a victim's file or locks their system and demands payment to restore access.	Up to 3 years of imprisonment. If it impacts critical national infrastructure, it can scale to life imprisonment	Up to Rs. 5 lakhs for basic offenses, massive penalties if public data

	Eg: The WannaCry attack which locked thousands of hospitals and corporate computers worldwide, demanding \$300-\$600 in bitcoin to unlock their files.	under Cyber Terrorism.	systems are disrupted.
Malware Distribution	The intentional creation, transmission of computer viruses, worms, trojan into a target computer network to damage systems. Eg: A cracked software was uploaded to a college site that secretly contained a hidden trojan designed to steal credit card details from anyone who installs it.	Up to 3 years of imprisonment.	Up to Rs. 2 to 5 lakhs.
Cyberbullying	The use of digital tools like social media to deliberately humiliate, threaten or harass an individual. Eg: A group of students created a public online forum page where they posted altered, embarrassing photos and hurtful comments about a classmate.	Up to 3 years of imprisonment.	Up to Rs. 1 to 2 lakhs.
Online Harassment	Unwanted digital communication directed at a specific person that causes them emotional distress, annoyance often involving online stalking. Eg: An individual constantly received abusive messages with location being tracked despite being blocked multiple times.	Up to 3 years of imprisonment for first conviction. Scales up to 5 years for repeat offenses.	Up to Rs. 5 lakhs.

Financial Fraud	Using internet services or software to deceive victims and illegally pull funds out of their bank accounts or digital wallets. Eg: An unauthorized caller pretended to be an insurance agent, convinced an employee to share their bank OTP and immediately siphoning out their savings.	Up to 3 years of imprisonment.	Up to Rs. 1 lakh, plus additional heavy penalties equivalent to the stolen amount ordered by the court.
Misinformation	Deliberately creating or spreading false, deceptive or manipulated facts online with the intent to cause public panic or destroying reputations. Eg: A photoshopped notice was floated on college site saying mid terms are cancelled causing lot of chaos.	Up to 3 years of imprisonment.	Court-mandated fines depending on the severity of the real-world unrest caused.
Website Defacement	An attack on a website that changes the visual appearance of the site, typically replacing the homepage with the hacker's own messages or explicit content. Eg: A hacker group exploited a vulnerability on a educational portal to replace the home screen with a political manifesto.	Up to 3 years of imprisonment.	Up to Rs. 5 lakhs.
Cyber Terrorism	An intentional attack utilizing computer networks to threaten the unity, security or integrity of nation or to strike terror in the minds of the public. Eg: Hackers hacked into a air traffic control system to shut down electricity across the institute.	Imprisonment for Life.	The court can penalize according to the scale of damage caused to national security.



PART 5: Data Protection Framework

Create a comprehensive data protection framework that all organizations operating in VIT's must follow. Your framework must cover the full data lifecycle.

Data Collection Rules

Organizations must minimize the data they collect, ensuring it is limited strictly to what is necessary for specified, explicit and legitimate purposes.

- **Legal Basis Verification:** Before collection, organizations must document a valid legal basis such as explicit consent, contractual necessity or legitimate interest under applicable privacy laws like GDPR or CCPA/CPRA.

- **Purpose Limitation:** Data collected for one purpose must not be repurposed without obtaining a new legal basis or explicit consent.
- **Technical Minimization:** Form fields, APIs, and telemetry trackers must be audited quarterly to strip out non-essential data collection. eg: collecting exact location data when a zip code suffices.
- **Collection Channel Security:** All data in transit during the collection phase must be encrypted using TLS 1.3. Clear text HTTP collection endpoints are strictly prohibited

Data Storage Rules

Personal data must be stored in a manner that ensures organizational security, confidentiality, and integrity.

- **Encryption:** All personal data stored in databases, cloud storage, backups must be encrypted. Encryption keys must be managed through an isolated Key Management Service (KMS) with automated 90-day rotation policies.
- **Access Control:** Implement Role-Based Access Control (RABC) and Attribute-Based Access Control (ABAC). Access to personally identifiable information must default to deny all. Employees are granted access strictly on a need-to-know basis, authenticated via Multi-Factor Authentication (MFA).
- **Pseudonymized and Anonymized:** High risk identifiers must be pseudonymized or tokenized at the database layer. Database administrators should only see masked data during standard operations.
- **Immutable Logging:** All access, modification or export of personal data must generate an immutable, tamper-evident log entry stored in a centralized SIEM (Security Information and Event Management) system, retained for at least 12 months.

Data Sharing Rules

Data transfers to third parties, vendors, or cross-border entities must be tightly controlled to prevent unauthorized downstream exposure.

- **Data Protection Agreements:** Organizations must execute formal DPAs or Vendor Risk Assessments with all third-party processors. These contracts must legally bind the vendor to the same or stricter data protection standards.

- **Cross-Border Transfer Mechanism:** Transferring data across jurisdictions must utilize valid legal mechanisms, such as Standard Contractual Clauses (SCCs), Binding Corporate Rules (BCRs), or adequacy decisions.
- **Secure API and transfer protocols:** Third-party data exchanges must occur via secure APIs utilizing mutual authentication, or via encrypted protocols like SFTP.
- **Data Clean Rooms and Masking:** When sharing data for analytics or research, organizations must use data clean rooms or apply dynamic data masking to prevent the re-identification of individuals.

User Consent Requirements

Consent must be a freely given, specific, informed indication of the user's wishes.

- **Granular Opt-In:** Pre-ticked checkboxes or opt-out defaults for data collection are prohibited. Users must explicitly opt-in to distinct processing activities e.g. Separate checkboxes for terms of service, marketing emails.
- **Clear and Plain Language:** privacy notices must be decoupled from standard terms and conditions. They must be written in clear, non-legalese language, detailing exactly who is collecting the data, what is being collected, and how it will be used.
- **Easy Withdrawal:** Withdrawing consent must be as easy, accessible, and fast as giving it. If a user can opt-in with one click, they must be able to opt-out with one click via a visible Data Privacy Dashboard or preference centre.
- **Consent Logging:** Organizations must maintain a verifiable cryptographic audit trail of how and when consent was obtained, including the version of the privacy policy the user agreed to.

Data Retention Period

Data must not be kept longer than necessary for the purposes for which it was processed.

- **Saturation Mapping:** Organizations must maintain a Data Retention Schedule that maps data categories to specific legal, regulatory, or business requirements.

- **Automated Tiers:** Storage systems must implement automated lifecycle policies that transition data from active databases to cold storage, and ultimately to a deletion queue based on the retention schedule.

Data Deletion Process

When data reaches its retention limit or a user exercises their right to be forgotten, deletion must be absolute and irreversible.

- **Logical vs Physical Deletion:** Soft deletion like marking a record as inactive in a database flag is insufficient. Organizations must perform hard deletions, removing the raw data completely from active production environments within 30 days of a valid request.
- **Cascading Deletion:** Deletion commands must automatically cascade across all internal subsystems, microservices, caches, and third-party vendor systems handling that specific user ID.
- **Backup Overwrites:** If data cannot be immediately extracted from compressed, immutable backup tapes, it must be cryptographically shredded. Otherwise, it must be overwritten or purged during the standard backup rotation cycle.
- **Hardware Destruction:** Physical drives, servers, or magnetic media decommissioned from data centres must be physically degaussed or shredded in compliance with NIST SP 800-88 Rev 1 standards for media sanitization.

Breach Notification Requirements

Organizations must have a battle-tested incident response plan to identify, contain, and report data breaches transparently.

- **Regulatory Notification:** In the event of a personal data breach resulting in a risk to user rights and freedoms, the organizations must notify the relevant Data Protection Authority (DPA) without undue delay and, where feasible, after becoming aware of it.
- **User Notification:** If the breach is likely to result in a high risk to the rights and freedoms of individuals such as identity theft or financial fraud, affected users must be notified directly and immediately via clear text email, push notification, or public notice.

- **Mandatory Notification Contents:** The breach notification must explicitly include:
 1. The nature of breach, including estimated numbers of individuals and data records compromised.
 2. The name and contact details of the Data Protection Officer (DPO).
 3. The likely consequences of the data breach.
 4. The remedial measures taken or planned to mitigate the negative impacts.
- **Breach Register:** Every security incident involving personal data regardless of whether it meets the threshold for regulatory notification must be documented in an internal data breach register, including the facts, its effects, and the remedial action taken.

PART 6: Corporate Responsibilities

All companies and organizations operating in VIT's must comply with the following cybersecurity responsibilities. Create at least 10 specific, enforceable corporate obligations.

Required Responsibilities (Minimum 10)

Responsibility 1: Mandatory Data Encryption at Rest and in Transit

- **The Obligation:** All corporate entities must encrypt any student, faculty, or institutional data using industry-standard encryption protocols. Universal or default encryption keys are strictly prohibited.
- Applies to all third-party vendors, software-as-a-service (SaaS) providers, and contractors handling university data.
- **Consequence for Non-Compliance:** Immediate suspension of data access privileges, a formal breach-of-contract notice, and a mandatory \$5,000 daily fine until verified encryption compliance is achieved.

Responsibility 2: Implementation of Multi-factor Authentication (MFA)

- **The Obligation:** Organizations must enforce Multi-Factor Authentication for all corporate accounts, employee portals, and systems that interface with the college's network or contain campus-related information.

- **Applies to all external vendors, campus partners and specialized student organizations with dedicated network portals.**
- **Consequence for Non-Compliance: Disconnection from the college network within 24 hours of detection and revocation of remote access rights until MFA deployment is audited and approved by the college IT department.**

Responsibility 3: Rapid Security Incident and Breach Reporting

- **The Obligation: In the event of a suspected or confirmed data breach involving campus information, the organization must notify the college's Chief Information Security Officer (CISO) within a strict 24-hour window from the time of discovery. The notification must include the scope of data exposed and initial mitigation steps taken.**
- **Applies to all companies, vendors, contractors, and affiliates operating on campus or managing campus data.**
- **Consequence for Non-Compliance: Termination of the operating contract, full liability for all legal and regulatory fines incurred by the college, and a permanent ban from bidding on future institutional contracts.**

Responsibility 4: Annual Independent Security Audits (SOC 2 type II)

- **The Obligation: Organizations handling sensitive campus data must provide the college with an updated, independent third-party cybersecurity audit report on an annual basis.**
- **Applies to core IT contractors, cloud hosting services, payment processors, and learning management system (LMS) providers.**
- **Consequence for Non-Compliance: Down classification to high-risk vendor status, a mandatory 15% withholding on all remaining contract payments, and contract termination if the audit is not produced within 60 days of the deadline**

Responsibility 5: Background Checks and Security Training for Staff

- **The Obligation:** Companies must conduct criminal background checks on all employees granted administrative or physical access to college IT infrastructure. Furthermore, all personnel must complete documented, annual cybersecurity awareness training.
- **Applies to managed service providers (MSPs), on-site technical contractors, and facilities management companies.**
- **Consequence for Non-Compliance:** Immediate removal of non-compliant personnel from campus grounds and a \$1,000 penalty per untrained or unvetted employee found accessing college property.

Responsibility 6: Strict Adherence to PCI-DSS Regulations

- **The Obligation:** Any organization processing financial transactions on campus or via college-branded portals must strictly comply with the Payment Card Industry Data Security Standard (PCI-DSS). Credit card data must never be stored on college-owned hardware.
- **Applies to campus dining providers, retail operators, parking services, and online ticketing vendors.**
- **Consequence for Non-Compliance:** Immediate shutdown of point-of-sale (POS) systems, suspension of the vendor's ability to process transactions on campus, and a requirement to indemnify the college against any payment processor penalties.

Responsibility 7: Mandated Annual Penetration Testing

- **The Obligation:** Organizations must contract a certified, independent ethical hacking firm to conduct an annual external and internal penetration test on all applications and infrastructure hosting college data. A remediated report

showing that all High and Critical vulnerabilities have been patched must be submitted to the college.

- Applies to core software developers, cloud providers, and any vendor hosting student records or portals.
- Consequence for Non-Compliance: Suspension of the software license or system usage across the campus, and a daily operational hold penalty of \$2,500 until a clean penetration test report is submitted.

Responsibility 8: Data Minimization and Secure Destruction Protocols

- The Obligation: Organizations may only collect and retain the minimum amount of student or institutional data necessary to perform their contracted duties. Upon contract termination or expiration, all college data must securely destroyed or returned within 14 days, using cryptographic erasure methods.
- Applies to marketing partners, research collaborators, student housing vendors, and alumni engagement firms.
- Consequence for Non-Compliance: Forfeiture of final contract disbursements, a formal report to consumer protection regulators, and potential civil litigation for unauthorized data retention.

Responsibility 9: Segregation of Corporate and Institutional Networks

- The Obligation: Companies operating physical offices or storefronts on campus must use a separate, firewall corporate network for their internal operations. They are strictly prohibited from bridging their corporate devices onto the core academic or administrative networks of the college.
- Applies to On-campus financial institutions, independent medical clinics, and national retail chains operating on campus.
- Consequences for Non-Compliance: Immediate termination of physical network drops and internet provisioning by campus IT, forcing the vendor to operate on isolated, self-funded cellular networks.

Responsibility 10: Designation of a Corporate Data Protection Officer (DPO)

- **The Obligation:** The organization must formally appoint a qualified Data Protection Officer to serve as the sole, accountable point of contact for the college's IT security team. This individual's contact information must be kept always updated to oversee the maintenance of internal security controls.
- **Applies to any company or organization collecting, storing, or processing Personally Identifiable Information (PII) of college students or staff.**
- **Consequence for Non-Compliance: Immediate Breach of Contract declaration.** If a security issue occurs and no responsive DPO is on file, the company faces an automatic \$25,000 administrative penalty and an immediate freeze on all pending institutional invoices.

PART 7: Government Responsibilities

Specify how government agencies of VIT's must protect national interests in cyberspace. Include concrete mechanisms for each area.

Protect National Infrastructure

Government agencies define Critical National Infrastructure (CNI) as physical or virtual systems so essential that their incapacity or destruction would debilitatingly impact national security, economic stability, or public health.

- **Air-Gapping and network Segmentation:** Physically isolating core Operational Technology (OT) networks such as nuclear power plants or water treatment control systems from the public internet.
- **Mandatory Security Baselines:** enforcing strict compliance frameworks like ISO/IEC 27001 that obligate infrastructure operators to implement continuous multifactor authentication (MFA) and routine patch management schedules.
- **Red Team Penetration Testing:** Deploying government-vetted offensive cybersecurity teams to simulate state-sponsored attacks against power grids, financial systems, and telecommunications networks to discover vulnerabilities before adversaries do.

Monitor Cyber Threats

To establish proactive defence, national agencies deploy vast threat intelligence architectures to maintain situational awareness over the domestic and global threat landscape.

- **Government Security Operations Centers (SOCs):** Operating 24/7 centralized command centers running Security Information and Event Management (SIEM) systems to aggregate and analyze massive data logs from all federal agencies.
- **Automated Threat Intelligence Sharing:** Utilizing Structured Threat Information Expression protocols to share real-time machine-readable Indicators of

compromise (IoCs) such as known malicious IP addresses or malware hashes with private sector partners.

- **Deep and Dark Web Surveillance:** Leveraging specialized automated scraping tools and human intelligence to monitor underground forums for leaked government credentials, zero-day exploits, or planned targeted campaigns.

Investigate Cybercrimes

When breaches occur, law enforcement agencies must balance swift threat mitigation with rigid legal adherence to ensure evidence remains admissible in court.

- **Evidentiary Search Warrants:** Obtaining specific digital warrants authorized by judicial bodies to legally compel Internet Service Providers (ISPs) and cloud vendors to hand over server logs, communications, and user metadata.
- **The Digital Forensics Workflow:** Law enforcement officers follow a highly technical, standardized sequence to preserve volatile evidence before it vanishes.
- **Phase 1: Evidence Acquisition and Write-Blocking**
Law enforcement uses hardware write-blockers to create bit-stream images of hard drives, phones, or servers without altering a single bit of the original data.
- **Phase 2: Chain of Custody Documentation**
Every transfer of physical or digital evidence is meticulously logged with timestamps, cryptographic hashes, and signatures to prove the evidence was not tampered with.
- **Phase 3: Forensics Analysis**
Investigators use software like EnCase or Cellebrite to extract hidden, deleted, or encrypted files, parse system registries, and reconstruct timeline events.

International Coordination

Because cyber threats respect no physical borders, national agencies must rely or international frameworks to locate and prosecute actors residing outside domestic borders.

- **INTERPOL Cybercrime Directories:** Actively participating in INTERPOL's global operations to share localized tactical intelligence, which triggers coordinated, multi-jurisdictional raids against ransomware syndicates.
- **Mutual Legal Assistance Treaties (MLATs):** utilizing formal government-to-government MLAT agreements to legally request foreign law enforcement agencies to gather electronic evidence or freeze assets located in their jurisdictions.
- **Joint Cyber Task Forces:** Embedding technical attaches directly into allied foreign nations cyber centers to rapidly share cross-border telemetry during global worms or massive supply chain attacks.

Awareness Programs

The human element remains the most frequent target for cyber adversaries. Government agencies lead large-scale educational initiatives to reduce the overall attack surface of the general populational and small businesses.

- **National Cybersecurity Awareness Campaigns:** Launching annual, coordinated media such as Cybersecurity Awareness Month centered on digestible, high-impact hygiene habits like recognizing phishing hooks, using password managers, and updating software.
- **Phishing Simulation Portals for Public Sectors:** Rolling out mandatory, unannounced internal phishing simulations for public sector employees, followed by immediate micro-learning modules for individuals who compromise the simulated emails.
- **SME Cyber Kit Distribution:** Providing small and medium-sized enterprises (SMEs) with free, open-source vulnerabilities scanners and risk assessments templates designed to secure local retail and regional commercial supply chains.

PART 8: Cyber Incident Reporting Framework

Design a step-by-step process for how cyber incidents are reported, investigated, and resolved in VIT's. You must also create a flowchart (as a separate deliverable).

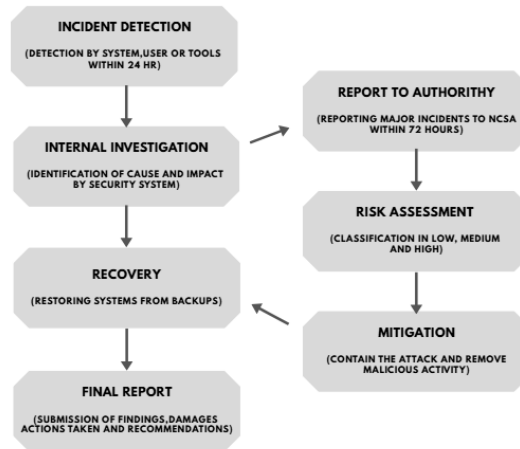
Reporting Process Steps

Step	Stage	Description (Student to Complete)
1	Incident Detected	Cyber incident is identified and records of initial evidence within 24 hrs.
2	Internal Investigation	Analyses of affected system and determination of impact is done by security team.
3	Report to Authority	Within 72 hrs major incidents must be reported to NCSA.
4	Risk Assessment	NCSA classifies incident as low, medium, high or critical risk.
5	Mitigation	Control the attack by isolating systems, blocking threats and patching vulnerabilities.
6	Recovery	Restore system from backup and verify normal operations.
7	Final Report	Submission of report with findings, damage, action taken and recommendations.

Deliverable Reminder

You must submit a separate FLOWCHART showing this complete process. Use tools like Canva, draw.io, Lucidchart, or PowerPoint SmartArt to create a professional diagram.

CYBERSECURITY INCIDENTS REPORTING FLOWCHART



<https://canva.link/8ne8cf5h13mq91n>

PART 9: National Cyber Security Authority (NCSA)

Design the organizational structure, responsibilities, and powers of the NCSA — the primary government agency responsible for cybersecurity in VIT's.

Organizational Structure

Ministry of Digital Affairs → Director General (DG) → Deputy Directors (Operations, Investigation, Policy) → Departments

Core Responsibilities

- Investigate cybercrimes.
- Protect critical infrastructure.
- Develop cybersecurity policies.
- Conduct public awareness programs.

Legal Powers

1. Order cybersecurity audits.
2. Require organizations to report data breaches within 72 hours.
3. Block malicious websites threatening national security.
4. Impose penalties for cybersecurity violations.

Investigation Process

Complaint Received → Evidence Collection → Digital Forensics Analysis → Suspect Identification → Legal Action

Departments

- **Threat Intelligence Unit – Monitors cyber threats and vulnerabilities.**
- **CERT (Incident Response Team) – Responds to cyberattacks and breaches.**
- **Digital Forensics Lab – Analyses digital evidence.**
- **Cyber Crime Investigation Unit – Investigates cybercrime cases.**
- **Cyber Policy & Compliance Division – Creates regulations and conducts audits.**

PART 10: AI and Emerging Technology Regulations

Create specific cybersecurity regulations for emerging technologies used in VIT's. For each technology, identify key risks and write enforceable rules.

Artificial Intelligence

Key Risks

- **Automated Malware Creation**
- **Data Privacy Violations**
- **AI bias in healthcare, banking and hiring decisions.**
- **AI generated phishing emails and scams.**

Regulations

- **High Risk AI systems must undergo security audits.**
- **User consent must for any personal information.**
- **Citizen can request for human review over any AI decisions.**
- **AI used for any cybercrimes must be punishable.**

Deepfakes

Key Risks

- **Financial fraud using AI-generated impersonation.**
- **Election misinformation and fake news.**
- **Reputation damage and cyberbullying.**
- **Identity theft through fake videos or voice calls.**

Regulations

- **Creating deepfakes for fraud or extortion is a criminal offense.**

- Social media platforms must remove verified harmful deepfakes within 24 hours.
- Victims have the right to request immediate takedown and compensation.
- All AI-generated videos and audio must contain a digital watermark.

IoT Devices

Key Risks

- Data leakage from connected devices.
- Botnet attacks using compromised IoT devices.
- Weak/default passwords.
- Unauthorized access to smart devices.

Regulations

- IoT manufacturers must provide security updates for 5 years.
- All IoT data must be encrypted during transmission.
- Default passwords must be changed during setup.
- Annual security testing is mandatory for critical IoT devices.

Cloud Computing

Key Risks

- Insider threats from cloud administrators.
- Unauthorized access to sensitive data.
- Loss of data due to service failures.
- Data breaches due to misconfigured storage.

Regulations

- Sensitive data must be encrypted at rest and in transit.
- Multi-Factor Authentication (MFA) is mandatory.
- Cloud breaches must be reported within 72 hours.
- Annual third-party security audits are required.

Digital Identity Systems

Key Risks

- Biometric data leakage.
- Fake digital identities.
- Unauthorized access to government services.
- Identity theft.

Regulations

- Biometric data must be stored in encrypted form.
- Citizens must be notified of unauthorized login attempts.
- MFA is mandatory for digital identity access.

- **Digital identities must undergo security audits every year.**

Autonomous Systems

Key Risks

- **AI decision-making errors.**
- **Hacking of self-driving systems.**
- **Remote takeover of autonomous devices.**
- **Manipulation of sensor data.**

Regulations

- **Critical software updates must be security tested before deployment.**
- **Annual cybersecurity certification is required.**
- **Autonomous systems must have an emergency manual override.**
- **All autonomous system actions must be logged for investigation.**

PART 11: Critical Infrastructure Protection

Create sector-specific cybersecurity requirements for each of the following critical infrastructure types in VIT's. Requirements should be practical and technically grounded.

Sector	Cybersecurity Requirements (Student to Complete)
Banks & Financial	• AI based fraud detection for unusual transactions. • Annual red team vs blue team cybersecurity exercises. • Mandatory Cyber Insurance for all banks. • MFA for all transactions above 10,000 rupees.
Hospitals & Healthcare	• All connected medical devices must receive security updates for 7 years • Emergency "Cyber Safe Mode "for all critical Equipment's during attack. • Quarterly drills for ransomware recovery. • Security certification for all IOT devices.
Airports & Aviation	• Zero Trust Architecture for airport networks. • Cyber security clearance for third party vendors. • AI based anomaly detection of air traffic systems. • Biometric access logs protected using encryptions.
Railways & Transport	• GPS spoofing detection systems. • Cybersecurity audits every 6 months. • Real time monitoring of smart ticket systems. • Secure communications channels for signal systems.
Power Plants & Energy	• No direct internet access to critical control systems. • Offline emergency control procedures. • Continuous monitoring of SCADA system. • Mandatory cyber drills stimulating nation state attack.
Government Data Centres	• Mandatory breach disclosure in 72 hours. • Access only through government-issued digital identities. • Annual Cybersecurity audits. • Sensitive data stored using quantum resistance encryption by 2030. • Citizen information classified as public, confidential and National security level.

PART 12: Awareness and Education

Design a National Cybersecurity Awareness Campaign for VIT's. Your campaign must reach all segments of society through age-appropriate and effective programs.

School Programs (Age 6-18)

- ***Cybersmart Kids***

Topics:

1. Safe internet usage
2. Cyberbullying Preventions
3. Fake News Identifications
4. Strong password creations

Activities:

1. Cyber Safety Week
2. Cybersecurity Quiz Competitions
3. "Spot The Scam "Games.

College & University Programs

- ***Cyber Ready Campus***

Modules:

1. Ethical Hacking Basics
2. Digital Forensic Awareness
3. AI & Cybersecurity
4. Data Privacy Laws

Activities:

1. Capture the Flag competitions
2. Cybersecurity Hackathons
3. Industry Workshops

Corporate Training Programs

- ***Secure Workforce Initiative***

Requirements:

1. Cybersecurity training every 6 months
2. Phishing stimulations Exercises
3. Password and MFA awareness

Activities:

1. Online test training
2. Stimulated phishing campaigns

Social Media Campaigns

- **#ThinkBeforeYouClick**
Platforms: Instagram, YouTube, LinkedIn and X(twitter)
Content:
 1. Short Awareness Reels and shorts
 2. Infographics
 3. Scam Alert contents and posts
 4. Cybersecurity QuizzesTargeted Audience:
 1. Students
 2. Working professionals
 3. Senior citizens

Public Awareness Workshops

- Locations: School, colleges, community centres, libraries and rural areas
Frequency: Monthly workshops and annual cyber safety week
Targeted Audience: Seniors, senior citizens, small business owners and students
Topics:
 1. Phishing and Online Scams
 2. Safe Digital Payments
 3. Password security
 4. Privacy protectionsDelivery Methods:
 1. Interactive demonstrations
 2. Games
 3. Expert Talks
 4. Hands on Awareness Activities with Real Examples

PART 13: International Cooperation

Define how VIT's will collaborate with other countries and international organizations to combat cybercrime that crosses national borders.

Cybercrime Investigations

Corporation of VIT with government and international agencies to investigate cybercrimes in cross national borders. The exchange of digital evidence, forensic reports and threat intelligence by the NCSA.

International operation against LockBit ransomware group (2024) involved law enforcements from countries working together for identification.

Information Sharing Agreements

Vit shall establish agreements with trusted nations, Cybersecurity organisations and CERTs to share malware, cyberthreats and attacks information's in real time. Indians Indian Computer Response Team regularly share cyber alerts with help of international CERT organisations to prevent large scale cyber-attacks.

Joint Operations

NCSA may participate in joint international cybercrime operations including ransomware attacks, cybercrimes, phishing, online fraud and cyber terrorism. Such operations may need coordination investigations.

INTERPOL regularly conducts multinational operations targeting cybercrimes across several countries.

Extradition Requests

VIT must extradition of cybersecurity requests of criminal operating from other countries under international treaties and agreements International cooperation against Revil Ransomware group identified attackers across borders.

Threat Intelligence Exchange

VIT shall share cyber threat informations , malware indicators and vulnerabilities alerts with international CERTs and trusted partners. Microsoft Exchange Cyberattacks (2021), countries and organisations shared threat intelligence to quickly detect and patch affected systems.

PART 14: Case Studies

Create 3 original fictional cybercrime cases set in VIT's. Each case must be realistic, detailed, and demonstrate how your law would be applied.

Case Study 1: The University Research Data Leak

Crime Category	Unauthorized Access / Data Breach
What Happened	A Last year engineering student discovered a misconfigured cloud database of National Research University of VIT. Instead of reporting he accessed and downloaded the confidential research data and records of student, faculties and staff. Breach exposed personal details over 30,000 of students and leaked on going medical research projects.
Law Violated	• Data Thefts • Unauthorised Access

	• Violation of rights to privacy • Breach of Data Protection
Investigation Process	The NCSA Digital Forensic Lab analysed server logs and identified unauthorized login sessions. Cloud access records and IP addresses linked the activity to the student. Investigators recovered copies of stolen data from his device.
Punishment Given	7 years punishment and 25 Lakhs fine
Lessons Learned	Quarterly security audits were made compulsory in all universities and implement role based access control for sensitive information.

Case Study 2: The Fake Hospital Payment Portal

Crime Category	Financial Fraud / Phishing
What Happened	Cybercriminal created a fake online portal of Hospitals in Vit. Patients received SMS of pending medical bills requires immediate payment. Thousands of citizens entered card details and otp resulting in tractions of worth Rs. 3cr
Law Violated	• Phishing • Financial Fraud • Identity Theft • Unauthorized collection of data
Investigation Process	Cyber crime investigation unit of NCSA traced phishing domains and identified the payment transactions records. Criminal network operating was investigated from multiple locations coordinating arrests with local police.
Punishment Given	10 Years imprisonment and 1 crore fine
Lessons Learned	Hospitals were required to implement verified payment gateways, anti-phishing awareness campaign and Digital signed patients communications.

Case Study 3: The Power Grid Ransomware Attack

Crime Category	Ransomware / Cyber Terrorism
-----------------------	------------------------------

What Happened	Ransomware Group targeted a National Power Grid Control Centre of VIT through malicious email attachments sent to an employee. The Malware encrypted operational systems and disrupted electricity distribution in several regions. Cryptocurrency was demanded in exchange of restoration.
Law Violated	• Malware Distribution • Cyber terrorism • Ransomware Attack • Critical Infrastructure Distribution
Investigation Process	The incident response team of NCSA isolated affected networks and restored services using secure backups. The Digital Forensic Lab analysed Ransomware Sample while international partners helped traced cryptocurrency payment.
Punishment Given	15 years imprisonment and Rs.5 crore fine.
Lessons Learned	Offline Backup along with annual ransomware stimulations and mandatory cybersecurity training for employees was required for power sector organisations.

PART 15: Future Recommendations

Based on your research, suggest forward-looking improvements and additions to VIT's cybersecurity law for the next 10 years. Consider how technology will evolve and what new threats will emerge.

AI Security (2025-2035)

There should be establishment of AI Governance Framework for annual AI security audits, transparency in automated decision making and a human oversight over critical sectors like law enforcement, healthcare and banking. The use of Artificial Intelligence should be used for cyberattacks, malware generation, phishing or deepfakes creation must be treated as serious cyber offenses.

Quantum Computing

By 2030 , there should be beginning of transitioning to quantum resistant cryptography to protect sensitive government and financial data. In critical infrastructures organisation should identify quantum risks and also upgrade encryption systems to post-quantum security standards

Privacy Protection

There should be stronger protection from future privacy law for biometric data, location data, behavioral profiling and smart device information. Explicit user content must be obtained by organisations before collecting sensitive information and must minimize unnecessary data collection.

Digital Identity

Development of secure national digital identity system using encryption, MFA and privacy by design principles. There should be full control by citizens over their digital identities and be able to monitor and report unauthorized access and misuse.

Cyber Warfare

VITS should define cyber warfare on a very large-scale cyber-attacks targeting government systems, infrastructure or national security. Government should establish a National Cyber defence Strategy to detect, prevent and respond immediately while cooperating with internal cybersecurity agencies.

Evaluation Criteria

Your project will be graded based on the following criteria. Review this carefully to maximize your marks.

Done	Deliverable	Requirements
☐	Project Report	Minimum 25 pages, wellformatted, all 15 parts completed, diagrams included
☐	PowerPoint Presentation	15 to 20 slides, covering all major sections of the law
☐	Flowchart: Cybercrime Reporting	Shows complete incident reporting process from detection to resolution

[]	Flowchart: Investigation Process	Shows NCSA investigation steps from complaint to judgment
-----	---	---

Criteria	Max Marks	Marks Obtained
Research Quality — depth and accuracy of information, use of real-world examples	20	
Law Structure — completeness, logical organization, and legal clarity of the law	20	
Innovation — originality of solutions, creative approach to cybersecurity challenges	15	
Technical Accuracy — correctness of technical details, cybersecurity concepts, and procedures	15	
Presentation — quality of the PowerPoint presentation and oral delivery	10	
Diagrams & Flowcharts — clarity, accuracy, and professionalism of visual deliverables	10	
Case Studies — realism, detail, and correct application of the law	10	
TOTAL	100	

Deliverables Checklist

Before submitting, ensure you have completed all required deliverables:

Done	Deliverable	Requirements
[]	Flowchart: Data Breach Response	Shows data breach response procedure for organizations

[]	Infographic: Citizens' Rights	Visual summary of all citizens' digital rights
[]	Infographic: Cybercrime Categories	Visual taxonomy of all defined cybercrimes with penalties
[]	Infographic: Security Framework	Visual overview of the data protection and corporate security framework

Good Luck!

This project challenges you to think like a lawmaker, a technologist, and a citizen. Research realworld cybersecurity laws (India's IT Act, GDPR, Budapest Convention) for inspiration. Be creative, be thorough, and make VIT's digital future secure!